

המערכת במבט מלא

מה נבנה, מה קיים, מה חסר — וההצעה להמשך.
סקירה מבוססת קוד, לא מבוססת תיעוד.

27

קבצי בדיקות

24

קולקציות CMS

7

מנועי דומיין

504

קבצי מקור

56,178

שורות קוד

— תוכן העניינים

01	תקציר מנהלים
02	ארכיטקטורה — מפת המערכת
03	שכבת הדומיין — שבעת המנועים
04	שכבת התוכן — 24 קולקציות ו-3 גלובלים
05	חווית המשתתף — הצד הציבורי
06	ה-Studio — צד המפיק
07	זהות, הרשאות ואבטחה
08	איכות, בדיקות וביצועים
09	תשתית, פריסה ותפעול
10	הפערים — מדורגים לפי חומרה
11	הצעות מוצר ופיצ'רים
12	תוכנית עבודה מוצעת
13	מוכנות לפרודקשן — רשימת תיוג
14	החלטות שנדרשות ממך

01 תקציר מנהלים

Hason היא פלטפורמת אירועים רב-ארגונית (multi-tenant) שבנויה נכון: שכבת דומיין טהורה ונבדקת, הפרדה חדה בין מנועים לתשתית, CMS מלא כמקור אמת, ודו-לשוניות עם RTL מהיסוד. הפער העיקרי אינו בארכיטקטורה — הוא בשלוש נקודות תפעוליות שחוסמות עלייה לאוויר: **מיילים לא נשלחים בפועל, אין מיגרציות בסיס נתונים, ופגם בטוקן הכניסה שמאפשר השתלטות על חשבון.**

מה טוב

- **הארכיטקטורה מחזיקה.** שבעה מנועי דומיין (~2,550 שורות) שהם לוגיקה טהורה — מכוונות מצב, כללי קיבולת, רשימות המתנה, גרף יכולות — מנותקים לחלוטין מ-Payload ומ-React. זו ההחלטה החשובה ביותר בפרויקט והיא נשמרה.
- **בידוד רב-ארגוני אמיתי.** `scopedByOrganization()` מחזיר תנאי `where` ברמת השורה ולא בוליאני — כלומר בידוד נאכף בשאילתה, לא בקוד היישום.

- **אין נתונים מפוברקים.** כמעט כל התוכן מגיע מה-CMS. שדות ריקים מוצגים ככאלה במקום להתמלא בדמו.
- **Networking עובד באמת** — קשרים, צ'אט מתמיד, פגישות, סריקת QR, vCard, WhatsApp deep-link. זה לא מוקאפ.
- **שמירות ארכיטקטורה אוטומטיות** — `tests/unit/architecture-guards.test.ts` סורק את מערכת הקבצים ואוכף את כללי החוקה. פתרון חכם וזול.

מה חוסם

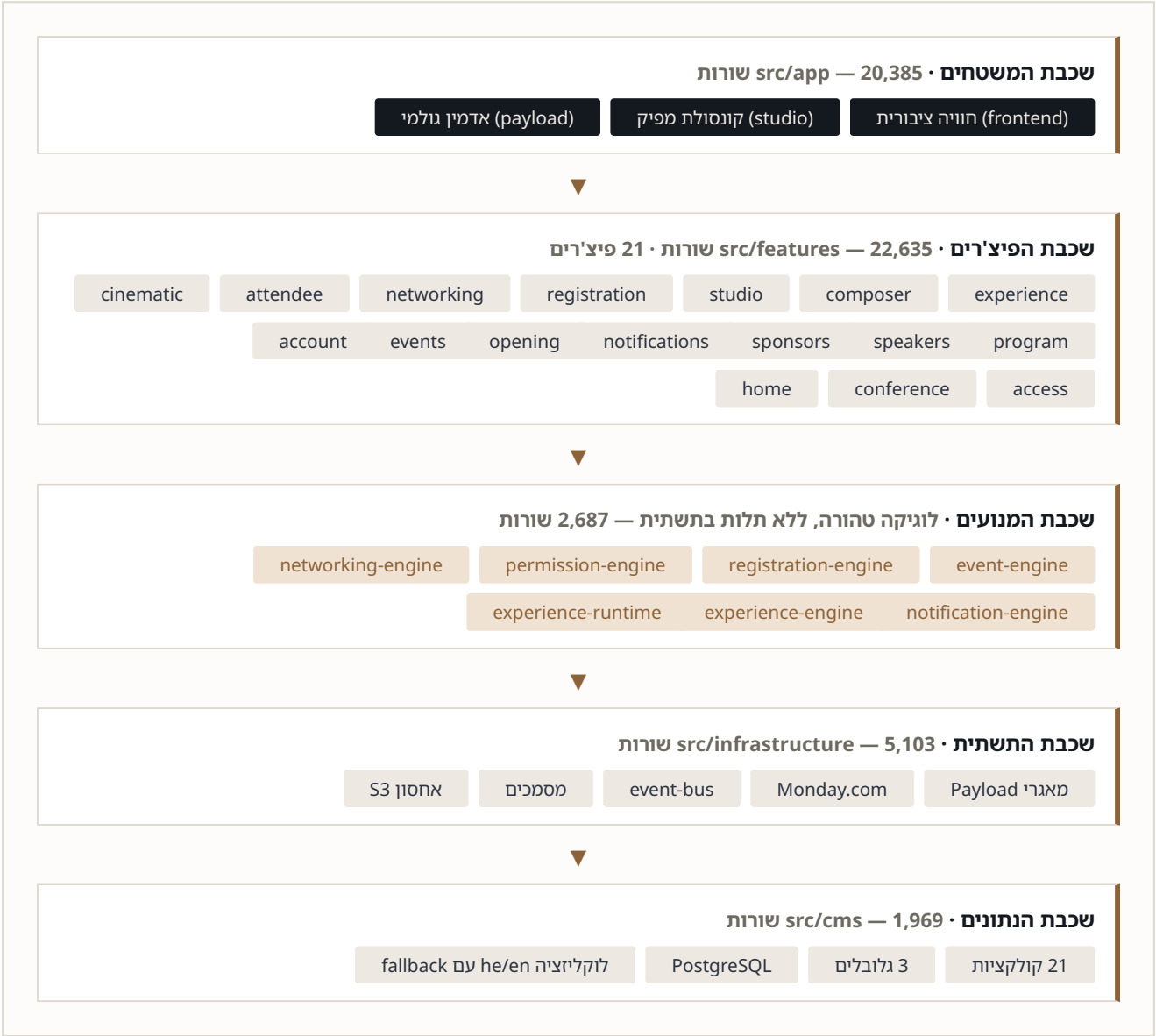
- **אין ערוץ מייל.** `devChannel.deliver()` מחזיר `'queued'` ולא שולח כלום. משתתף לא יכול לקבל אישור הרשמה או קישור כניסה. לולאת המשתתף לא ניתנת לבדיקה מקצה לקצה.
- **אין מיגרציות.** הסכמה מסונכרנת ידנית עם `PAYLOAD_DB_PUSH=true`. זהו הסיכון התפעולי הגדול ביותר.
- **טוקן הכניסה זהה במבנה לעוגיית הסשן.** פגם קריטי — פירוט בפרק 07.
- **אין שכבת קאשינג כלל.** אפס `unstable_cache`, אפס `revalidate`, כל עמוד ציבורי הוא `force-dynamic`. היעד של 600 משתמשים במקביל לא יעמוד בזה.
- **חוב טכני של כפילויות.** שתי מערכות סצנות, שתי מערכות תפקידים, שני עצי ניתוב ב-Studio, שתי מערכות תרגום.

שורה תחתונה

המערכת קרובה מאוד לתפקוד מלא. הפער אינו "עוד פיצ'רים" אלא **שלושה שבועות של עבודת תשתית: מייל, מיגרציות, אבטחה וקאשינג.** אחריהן — הבסיס יציב מספיק להתחיל להוסיף.

02 ארכיטקטורה — מפת המערכת

המערכת בנויה בחמש שכבות עם כיוון תלות אחד: מבפנים החוצה. המנועים לא יודעים דבר על Payload, על Next.js או על React.



Stack טכנולוגי

רכיב	גרסה	הערה
Next.js	App Router 15.4	נעול לגרסה מדויקת — נכון, בגלל Payload
React	19	Server Components כברירת מחדל
Payload CMS	3.x	מוטמע באותה אפליקציה, לא שירות נפרד
PostgreSQL	@payloadcms/db-postgres	ללא מיגרציות — ראה פרק 09
Tailwind CSS	4.0	טוקנים בלבד, ללא inline styles
next-intl	4.0	מחווט אך כמעט לא בשימוש — ראה פרק 05
Zod	3.24	סכמות סצנות, מדיניות סיסמה, טופס הרשמה
Vitest	4.1	27 קבצי בדיקה, ~160 מקרים
motion	12.42	מותקן אך הועדף CSS-first — ראה דוח 13

03 שכבת הדומיין — שבעת המנועים

זהו לב המערכת ואיכותו גבוהה. כל מנוע הוא לוגיקה טהורה שניתן לבדוק בלי בסיס נתונים.

מנוע	שורות	מה הוא עושה	בדיקות	מצב
Event Engine	584	שלבי מחזור חיים, מעברים חוקיים, גרף יכולות, מנוע מוכנות (readiness) שמפיק ממצאים חוסמים, EventHealth-1	3 קבצים	מוקפא
Registration Engine	571	מכונת סטטוס, קיבולת, רשימת המתנה, מצב→תוצאה, אנונימיזציה (GDPR), התנגשויות לויז, אירועי דומיין, תפר אינטגרציה שמור	2 קבצים	מוקפא
Event Engine Readiness	310	הרכיב הגדול ביותר — כללים שקובעים מתי אירוע מוכן להשקה	כן	בנוי
Permission Engine	140	5 תפקידים, 8 יכולות, הענקות מתחומות לפי אירוע	6 מקרים	כפילות
Networking Engine	145	מכונת מצב לקשרים (ממתין/מאושר/מושתק) ולפגישות	חלקי	חלקי
Notification Engine	181	חוזה ערוץ, outbox, תבניות הרשמה	אין	לא מספק
Experience Engine	524	רג'יסטרי סצנות, resolver, loader, ולידציה, inspector	3 קבצים	דור ישן
Experience Runtime	542	descriptor, composition, lifecycle, רג'יסטרי חדש	3 קבצים	דור חדש

חוב טכני: שני דורות של מנוע חוויה חיים במקביל

experience-engine משרת את ה-Studio הישן (classic) ואת features/experience ;
experience-runtime משרת את הפרונט הציבורי, את src/scenes ואת הקונסולה החדשה. לשניהם types/scene.ts משלהם ו- registry.scene-registry.ts משלהם. 33 מול 27 אתרי ייבוא. זה לא קוד מת — שניהם פעילים, וזו בדיוק הבעיה.

מערכת הסצנות — גם כאן שתי מערכות

מערכת	סוגים	הסוגים
features/experience מסמכי חוויה, ולידציית Zod	10	hero · story · content · agenda · session-list · speaker-grid · venue · sponsor-grid · faq · registration-cta
scenes/conference-scenes דף הכנס הקולנועי	16	nav · footer · arrival · story · quote · moments · featuredSessions · countdown · facts · sponsors · actIntro · speakers · program · venue · closing
scenes/opening-scenes דף הבית / portal wall	7	nav · footer · featuredHero · hero · portalWall · story · moments · closing

04 שכבת התוכן — 24 קולקציות ו-3 גלובלים

כל קולקציה נושאת יחס ל- `organization` ומשתמשת באחת משלוש קביעות גישה מ- `access-presets.ts`.

ליבה ותוכן

קולקציה	מה היא מודלת
<code>organizations</code>	הדייר (tenant). שם מתורגם, slug. גישה מותאמת.
<code>users</code>	משתמש Payload עם <code>auth: true</code> ומערך <code>grants[]</code> (תפקיד + ארגון + אירוע אופציונלי).
<code>events</code>	הכנס. מערך <code>composition[]</code> (סצנה/מוסתר/וריאנט/צפיפות/הדגשה), כותרת ומיקום מתורגמים, קבוצת <code>opening</code> . טיוטות מופעלות.
<code>experiences</code>	רצף סצנות בעל שם, קשור ל- <code>scenes</code> . טיוטות מופעלות.
<code>scenes</code>	כותרת מתורגמת + שדה JSON מתורגם <code>content</code> + סוג + <code>enabled</code> . זה מה שה-Composer כותב.
<code>media</code>	<code>upload: true</code> , טקסט חלופי מתורגם.

תוכנית ואנשים

קולקציה	מה היא מודלת
<code>sessions</code>	הישות העשירה ביותר: כותרת/תיאור/מסלול/ציוד מתורגמים, סוג מושב, דוברים, חדר, קיבולת, רשימת המתנה, חלונות הרשמה פר-מושב, דדליין ביטול.
<code>rooms</code>	שם ומיקום מתורגמים, קיבולת.
<code>speakers</code>	שם/תפקיד/חברה/ביוגרפיה מתורגמים, תמונה, קישורים חברתיים, קישור אופציונלי לחשבון משתתף.
<code>sponsors</code>	דרג, לוגו, אתר, תיאור מתורגם, סדר.

הרשמה וזהות

קולקציה	מה היא מודלת
participants	חשבון משתתף: אימייל, passwordHash, -totpSecret (שניהם מוסתרים באדמין), טלפון, העדפות קשר, תזונה ונגישות, blocked, anonymizedAt.
registrations session-registrations	סטטוס, תשובות, מיקום ברשימת המתנה, פקיעת הצעה.
registration-settings	מצב פר-אירוע, קיבולת, חלונות פתיחה/סגירה, הודעת אישור מתורגמת, מתגי איסוף נתונים.
participant-sessions	hash של טוקני קישור-קסם וסשן, מטרה, פקיעה, שימוש.
account-grants	הענקת תפקיד (ארגון + חשבון + תפקיד + אירוע + מי העניק ומתי).
notifications	outbox: סוג, ערוץ, סטטוס, שפה, נושא, גוף, זמן שליחה.

נטוורקינג

קולקציה	מה היא מודלת
networking-profiles	כותרת, ביו, תחומי עניין, נראות.
networking-connections	מבקש↔נמען, סטטוס, mutedBy.
networking-chat-messages	גוף הודעה, readAt. תקרה של 200 הודעות לשרשור, 2000 תווים להודעה.
networking-meetings	מארח/אורח, משבצות זמן, מכונת מצב.

גלובלים

site (מצביע לכנס הפעיל) · opening-page (הרכב דף הבית — hero/events/story/moments/closing, כולם מתורגמים) · platform-settings (שם הפלטפורמה, מתורגם).

מודל הגישה

קביעה	חוקים	חלה על
publicContentAccess	קריאה ציבורית · content:write לעדכון · content:launch למחיקה	events, experiences, scenes, sessions, rooms, sponsors
orgContentAccess	קריאה ציבורית · content:write שינוי	media, speakers לכל
registrationAccess	מתוכם לחלוטין · manage / registrations:read	participants, registrations, settings, sessions-reg, notifications + כל קולקציות הנטוורקינג

05 חוויית המשתתף — הצד הציבורי

כל הניתוב הציבורי מקודם ב- `[locale]` עם middleware שמפנה לפי עוגיית שפת המשתתף.

המסלולים

מסלול	מצב	מה בפועל
<code>/[locale]</code>	אמיתי	דף הבית הוא הכנס הפעיל, לא אינדקס. אם אין כנס מסומן — מסך "בקרוב" דו-לשוני קשיח.
<code>/events/[slug]</code>	אמיתי	אותו צינור, מתוחם ל- <code>slug</code> .
<code>/experiences/[slug]</code>	אמיתי	מסמך חוויה גנרי מה-CMS, ללא כרום.
<code>/program</code>	אמיתי	<code>buildProgramModel</code> + חיפוש, סינון ומגירת פרטים.
<code>/speakers</code> <code>/speakers/[id]</code>	אמיתי	פותר יחס הפוך דובר↔מושב.
<code>/info</code>	חלקי	עובדות מקום מה-CMS, אבל <code>FACT_HINTS</code> מכיל טקסטי גיבוי קשיחים (נגישות, תחבורה, חניה, מלונות).
<code>/contact</code>	חלקי	מושך כותרת/תאריך/מיקום מהאירוע הפעיל; שאר הטקסט קשיח.
<code>/connect/[token]</code>	אמיתי	נחיתת QR של תג. מטפל בסריקה עצמית, בהיעדר כנס משותף ובמצב מנותק. מערך ההקשרים ("נפגשנו במליאה") קשיח.
<code>/enter</code>	אמיתי	צורך קישור-קסם → מקים ששן → מפנה ל- <code>/me</code> .
<code>/events/[slug]/register</code>	אמיתי	עמוד יחיד (461 שורות). מאמת חוזק סיסמה, בודק התנגשויות לויז' חוצות-כנסים, נרשם, מקים ששן, יוצר פרופיל נטוורקינג. אין מסכי <code>confirm/success</code> נפרדים — מצב דרך <code>query</code> .

פורטל המשתתף `/me`

כמעט הכול אמיתי, ללא placeholders. `/me/page.tsx` (842 שורות) הוא דלת החשבון: התחברות, TOTP, קישור-קסם, הצטרפות/עזיבת כנס, תצוגת סדר יום. `/me/networking` (890 שורות) הוא העמוד הגדול ביותר — ספרייה, סינון, סינון לפי ארגון, פעולות חיבור. `/me/messages` מאחד קשרים, פגישות והכרזות מכל הכנסים שהמשתתף מצטרף אליהם — אך עם תקרה שקטה של 5 כנסים (`.slice(0, 5)`).

נטוורקינג — עובד, אבל לא בזמן אמת

קשרים מכונת מצב אמיתית ממתין / מאושר / מושתק, עם הרשאה מבוססת deny-by-default.	צ'אט מתמיד, אך בפולינג router.refresh() כל 12 שניות, נעצר כשהלשונית מוסתרת. אין socket.
פגישות מלא הצעה / אישור / ביטול / הצעת מועד חלופי.	סריקה BarcodeDetector מקורי עם נפילה לשדה קוד ידני. Firefox ו-Safari יגיעו לנפילה.
vCard הורדה אמיתית מחזיר text/vcard תקין.	WhatsApp הפניה מוגנת 302 עם whatsappLinkFor() ; המספר עצמו לעולם לא מוצג.

ממצא: הלוקליזציה כמעט לא בשימוש

src/i18n/messages/en.json שוקל **222 בתים** ומכיל בלוק common בלבד. למעשה 100% מטקסט המשתתף קשיח בתוך אובייקטים inline בצורת { he: '...', en: '...' } (CINEMATIC_UI , LOUNGE_UI , COPY , TEXT). next-intl מחווט אך אינו משמש לתוכן. זו סתירה ישירה לעיקרון "שום דבר לא קשיח".

ממצא: תמונות דמו בקוד המקור

cinematic-service.ts:33 — speakerPhoto() מחזיר https://i.pravatar.cc/640?img=N ומשמש כברירת מחדל בשורות 134 ו-220. fallbackConference() ב-cinematic-content.ts:154 מספק כנס דמה שלם. next.config.ts מתיר במפורש i.pravatar.cc ו-picsum.photos כארחי תמונות מרוחקים.

מנותק מהצד הציבורי: src/features/opening (20 קבצים — portal-carousel, hero-atmosphere, scene-bleed) נערך מה-Studio (/studio/homepage) אך **אף מסלול ציבורי אינו מרנדר אותו** — /[locale]/page.tsx משתמש ב-descriptor של conference. כלומר: יש עורך לדף בית שאיש אינו רואה.

06 ה-Studio — צד המפיק

מבנה הניתוב — שני עצים חיים, שניים ריקים

עץ	מצב	מה הוא משרת
(studio)/studio/ (console)	ראשי	/studio, media, people, participants, communications, checkin, insights, homepage, activity, experiences/[slug], new
(studio)/studio/ (classic)	ישן אך פעיל	/studio/events + 11 תת-עמודים לאירוע, ועוד organization, team
(studio)/console	ריק	5 תיקיות ללא קבצים — שאריות משינוי שם
(studio)/studio/events	ריק	12 תיקיות ללא קבצים — מראה של classic

(classic) הודר במכוון: console-sidebar.tsx מקשר אליו תחת קבוצת "Workspace",
 1- (classic)/layout.tsx מרנדר אותו בתוך ה- ConsoleShell. אך (classic)/actions.ts נותר קובץ ה-server actions המשותף לשני העצים — הקונסולה מייבאת ממנו archiveEventAction, saveHomepageAction, duplicateEventAction 1- launchExperienceAction. לכן classic אינו ניתן להסרה כמות שהוא.

משטחים כפולים בין העצים: check-in (בקונסולה יש סורק מצלמה אמיתי, ב-classic טופס הדבקת קוד), media, participants, people, notifications ↔ communications, homepage/opening. גרסאות הקונסולה הן ברמת הארגון; גרסאות classic הן פר-אירוע.

מודולי ה-Studio — כולם אמיתיים ומחווטים

לא נמצא אף עמוד placeholder. כל מודול מייבא שירות דומיין:

מודול	שירות
Check-in	checkInByToken + סריקת מצלמה אמיתית
Participants	listRegistrations / getParticipantsAdmin + 7 פעולות (העברה, חסימה, מחיקה)
People	listAllGrants + searchAccounts + הענקה/שלילה
Program	listAgenda + יצירה/עדכון/מחיקה של מושבים
Registration	getRegistrationSituation, אישור/דחייה/קידום/ביטול/הגדרות
Sponsors · Venue · Media	listSponsors · updateVenueAction · listMedia + העלאה
Communications	רשימה + broadcastAnnouncementAction
Homepage / Opening	getHomepageDraft, buildOpeningDescriptor, הזזה/הפעלה של סצנות
Insights	getRegistrationCounts — קריאה בלבד בכוונה
Activity	אשף 5 שלבים (577 שורות) + מנוע קיבולת
DNA · Settings	soon: true — הפריטים היחידים שאינם קישורים

ה-Composer — הפער החד ביותר ב-Studio

שכבת השמירה כולה היא שורה אחת:

```
await sceneContentRepository.updateSceneContent(scene.id, locale, scene.content)
```

אובד ברענון כל השאר סדר הסצנות (move), מתג הפעלה/כיבוי, שינוי שם (title), שכפול (מדולג במפורש), וטיטות ה- identity כולה (אווירה, גוון).	נשמר היום תוכן סצנה בלבד ערכי שדות של scene.content — ורק עבור השפה שנבחרה כרגע, ורק לסצנות שה-id שלהן אינו מכיל -copy .
---	--

מצהיר על types/persistence.ts

עם הערה מפורשת: ComposerPersistence { saveDraft, history, restore, submitForReview, launch } "no implementation exists yet by design". **אין אף מימוש.** אין גרסאות, אין שחזור, אין תהליך אישור, אין Payload.launch-diff כן מחזיק { drafts: true } versions: על events/experiences/scenes — אבל ה-Composer לא קורא ולא כותב אותם.

למה עדיין צריך את /admin

- **יצירת משתמשי users** — /studio/people "לא יוצר אף אחד", רק מעניק תפקידים לחשבונות קיימים. הקמת האדמין הראשון מחייבת אדמין.
- **platform-settings** — אין עורך ב-Studio.
- **קולקציות הנתוורקינג** — אין להן שום משטח ב-Studio.
- **גרסאות וטיטות** — נגישות רק דרך אדמין.
- **מבנה סצנות** — ה-Studio עורך תוכן, לעולם לא סוג/סדר במסד.

Monday.com

שני קבצים, 90~ שורות. לקוח GraphQL דק עם שתי מוטציות בלבד (create_update , create_item), מושבת אלא אם שני משתני הסביבה קיימים. נורה **רק על התוצאה הראשונית** של הרשמה. חד-כיווני, fire-and-forget. מעברי סטטוס אינם מסונכרנים; אין webhooks, אין מיפוי עמודות.

07 זהות, הרשאות ואבטחה

מודל הזהות

participant-identity-service.ts (450~ שורות) עושה הכול: התחברות סיסמה (script), מלח לכל סיסמה, timingSafeEqual), קישור-קסם (טוקן 32 בתים, נשמר כ-TTL hash של 15 דקות, חד-פעמי), TOTP (מימוש ידני של RFC 6238, HMAC-SHA1, סטייה ±צעד אחד), ששנים, טוקני כניסה וטוקני חיבור.

התחברות ל-Studio משתמשת באותה עוגייה של המשתתף — `getStudioAccess()` פותר את המשתתף ואז שולף הענקות. מנגנון `payload.auth()` הוא רק גיבוי.

חמור · בלבול טוקנים — נתיב להשתלטות על חשבון

עוגיית הסשן נבנית כך:

```
participant_session = ${participantId}.${sign(participantId)}
```

וטוקן הכניסה שמודפס על ה-QR של הכרטיס נבנה כך:

```
entranceToken = ${registrationId}.${sign(registrationId)}
```

שני המבנים **זהים לחלוטין ואינם ממורחבים בקידומת**. טוקני `connect` ו-`totp` כן ממורחבים כראוי — טוקן הכניסה נשכת. משמעות: מי שמדביק טוקן כניסה מודפס לתוך עוגיית `participant_session` יאומת כמשתתף שה-id שלו שווה מספרית ל-`registrationId`. מכיוון שמדובר בשתי סדרות Postgres נפרדות, התנגשויות מובטחות.

הטוקן אכן מוצג כ-QR — `qrValue: entranceToken : participant-experience-builder.ts:233`

התיקון: שורה אחת — ``${id}.${sign(`entrance.${id}`)}``. יש לתקן לפני כל הדפסת תגים.

חמור · הסוד עלול להיות ריק

— ללא שום אימות בהפעלה. `SECRET = REGISTRATION_LINK_SECRET || PAYLOAD_SECRET || ''`

`src/config/env.ts` אכן מגדיר סכמת Zod שדורשת `PAYLOAD_SECRET.min(32)`, אבל `getServerEnv()` אינו

נקרא באף מקום במערכת (אומת: המופע היחיד הוא ההגדרה עצמה). פריסה שגויה תחתום את כל הסשנים וה-QR במפתח ריק.

עוד ממצאי אבטחה

נושא	מצב	פירוט
עוגיית ששן	חלש	ללא פקיעה מובנית, ללא nonce, ללא גרסה. אישור bearer קבוע — אין "התנתק מכל המכשירים", אין ביטול, אין רוטציה.
הגבלת קצב	אין	אפס התאמות ל-rate-limit או 429. בקשות קישור-קסם, הרשמה וסריקות check-in ללא חסם.
חסימת התחברות	חלקי	5 כשלים / 15 דק', ב- Map מקומי לתהליך — מתאפס בכל פריסה, חסר משמעות ביותר מתהליך אחד.
CSRF	חלקי	נשען על בדיקות מקור של server actions ועל sameSite=lax. שני route handlers של קישור-קסם משנים מצב ב-GET.
ולידציית קלט	חלקי	Zod ב-14 קבצי סכמות סצנה, במדיניות סיסמה ובטופס ההרשמה. 16 קבצי server actions מקבלים מחרוזות גולמיות.
סוד TOTP	בעיה	נשמר כטקסט גלוי ב- participants.totpSecret.
כותרות אבטחה	אין	next.config.ts ללא headers() — אין CSP, HSTS, X-Frame-Options או Referrer-Policy.
overrideAccess: true	בכוונה	נפוץ במאגרי משתתפים ("אין actor של CMS"). המשמעות: הבידוד נאכף בתנאי where ידניים, לא בשכבת הגישה.
בידוד ארגוני	טוב	organizationsWithPermission + cms/access.ts — ברמת השורה, נכון.

חוב: שתי מערכות תפקידים במקביל

src/permission-engine : 5 תפקידים — owner, producer, editor, door, viewer · 8 יכולות · מתוחם לפי eventSlug. משמש את ה-Studio.

src/auth : 8 תפקידים —

platformOwner, orgAdmin, eventManager, contentEditor, registrationManager, volunteerManager, reviewer, readOnly

· 11 הרשאות · מתוחם לפי ארגון. משמש את שכבת הגישה של Payload.

שתי אוצרות מילים, שני מאגרי הענקות, שני צירי בידוד. יכולת המשתמש ב-Studio וגישתו למסד מחושבות מטבלאות שונות.

08 איכות, בדיקות וביצועים

מה מכוסה

27 קבצים, ~160 מקרים, כולם בדיקות יחידה ב-Vitest בסביבת node, ועוד קובץ אינטגרציה אחד.

· architecture-guards.test.ts — סורק את מערכת הקבצים ואוכף את כללי החוקה (אין ייבוא ישיר של רכיבי סצנה ממשטחים ציבוריים, אין הסתעפות type ===. בשכבת הרינדור). פתרון חכם, זול ובעל ערך אמיתי.

- מכונות מצב: registration (16 מקרים), permission (6), lifecycle, readiness, event-health, connection-lifecycle (3).
- snapshots של חוויות ציבוריות, composer, composition, inspector, studio-core.
- TOTP, מדיניות סיסמה, חסימת התחברות — ברמת האלגוריתם.

מה לא מכוסה כלל

חסר	השלכה
בדיקות e2e (אין Playwright / Cypress)	מסלול ההרשמה המלא — 461 שורות — לא נבדק אוטומטית מעולם
בדיקות route handlers ו-server actions	16 קבצי actions ללא כיסוי
בדיקות מסלולי זהות	קישור-קסם, ששן, טוקן כניסה — בדיוק המקום שבו נמצא הפגם החמור
notification-engine	אפס בדיקות
בדיקות עומס וביצועים	יעד 600 משתמשים לא נבדק מעולם
CI	לא נמצאה תצורה. השערים רצים ידנית.
ספי כיסוי	אין

בדיקת האינטגרציה היחידה מדולגת בשקט

היא הבדיקה היחידה שנוגעת במסד — 5 מקרים מול Postgres
אמיתי עם `overrideAccess: false`. אך היא עטופה ב- `describe.skipIf(!TEST_DATABASE_URL)` ואינה
מחווטת ל- `npm test`. בפועל היא פשוט לא רצה. גם
`src/registration-engine/schedule/conflict.test.ts` לא רצה — תצורת `include` של `vitest` מכסה רק
`tests/**`.

ביצועים — היעד של 600 משתמשים במקביל

גורם	מצב	פירוט
קאשינג	אפס	אין <code>unstable_cache</code> , אין <code>revalidate</code> , אין <code>cache()</code> של React. כל עמוד ציבורי הוא <code>force-dynamic</code> — סבב מסד מלא לכל בקשה של כל משתמש.
Invalidation	גס	<code>revalidatePath('/', 'layout')</code> נקרא בהיקף רחב בכל כתיבה.
יחס לקוח/שרת	כבד	96 רכיבי לקוח מול 16 קבצי <code>server actions</code> — חבילת לקוח כבדה למוצר מוכוון-תוכן.
שאליות	N+1	<code>depth: 2</code> עם <code>limit: 500</code> / <code>1000</code> ; לולאות שמנפיקות שאליתה לשורה ב- <code>payload-event-repository.ts</code> (297, 273, 251), <code>program-service.ts</code> (397, 242), ולולאה מקוננת ב- <code>notifications-service.ts:109</code> .
זמן אמת	פולינג	צ'אט כל 12 שניות. 600 משתמשים $\approx$ 50 בקשות דינמיות לא-מקושרות בשנייה בבסיס, מול תהליך Node יחיד.
תמונות	תקין	<code>sharp</code> + <code>avif/webp</code> . אך <code>remotePatterns</code> מתיר רק מארחי דמו.

09 תשתית, פריסה ותפעול

תחום	מצב	פירוט
יעד פריסה	יחיד	לפי <code>DEPLOY.md</code> : שרת Hetzner Ubuntu אחד — Node 20 + PM2 + Nginx — <code>Certbot</code> + <code>Postgres</code> מקומי, עם 4GB swap לבנייה. נקודת כשל יחידה, ללא מסלול לסקיילינג אופקי.
מיגרציות	אין	<code>DEPLOY.md</code> שורה 143 מציין שאין סקריפט <code>payload migrate</code> . הסכמה מסונכרנת בהפעלת <code>PAYLOAD_DB_PUSH=true</code> ידנית לכל שינוי. הסיכון התפעולי הגדול ביותר במערכת.
קונטיינריזציה	אין	<code>docker-compose.yml</code> הוא <code>dev-only</code> (<code>postgres</code> + <code>postgres-test</code>). האפליקציה עצמה אינה ארוזה.
גיבויים	בסיסי	<code>pg_dump</code> לילי ב- <code>cron</code> . מדיה מקומית מגובה ב- <code>tar</code> ידני.
אחסון מדיה	מותנה	תוסף S3 מופעל רק אם <code>S3_*</code> מוגדרים; אחרת דיסק מקומי ואובדן בבנייה מחדש.
לוגים	שלד	<code>src/shared/logging/logger.ts</code> — לוגר JSON נקי עם <code>transport</code> ניתן להחלפה, אבל שום שום transport לא מותקן .
ניטור	אין	Sentry, APM, אין <code>endpoint</code> בריאות, אין <code>correlation ids</code> .
סביבת ריצה	לא מאומתת	<code>getServerEnv()</code> מוגדר ואינו נקרא. אין <code>fail-fast</code> על תצורה חסרה.

10 הפערים — מדורגים לפי חומרה

P0 · חוסמי עלייה לאוויר

#	פער	מדוע זה חוסם	מאמץ
1	בלבול טוקן כניסה	נתיב השתלטות על חשבון מ-QR מודפס. חייב להיסגר לפני הדפסת תגים.	שעה
2	סוד ריק אפשרי	אין אימות סביבה; פריסה שגויה חותמת במפתח ריק.	שעתיים
3	אין ערוץ מייל	משתתף לא יכול לקבל אישור או קישור כניסה. הלולאה הציבורית שבורה.	יום
4	אין מיגרציות	DB_PUSH ידני על פרודקשן = סיכון לאובדן נתונים בכל שינוי סכמה.	2 ימים
5	אין הגבלת קצב	נקודות קצה של קישור-קסם והרשמה פתוחות לניצול לרעה.	יום
6	אין קאשינג	יעד 600 משתמשים לא ריאלי מול force-dynamic גורף.	3 ימים

P1 · פוגע במוצר

#	פער	ההשלכה	מאמץ
7	Composer לא שומר מבנה	סדר, הפעלה, שם ושכפול אובדים ברענון. ה-Studio אינו עורך אמיתי.	4 ימים
8	אין גרסאות ושחזור	ComposerPersistence מוצהר ולא ממומש. אין launch-diff, אין תהליך אישור.	שבוע
9	אין audit trail	"מי אישר מה ומתי" — דרישת סף לרוכש ממשלתי. ממודל, לא ממומש.	3 ימים
10	תוכן קשיח	en.json = 222 בתים. כמעט כל טקסט המשתתף inline. סתירה לעיקרון הליבה.	שבוע
11	תמונות דמו בקוד	i.pravatar.cc מותר ב-next.config ומשמש כברירת מחדל לדוברים.	יום
12	אין ניטור ולוגים	אין transport, אין Sentry, אין health endpoint. תקלה בפרודקשן לא תיראה.	יומיים
13	אין בדיקות e2e	מסלול ההרשמה והזהות — הקריטיים ביותר — ללא כיסוי.	4 ימים
14	isolation test מדולגת	בדיקת הבידוד היחידה לא רצה בפועל.	שעתיים

P2 · חוב טכני

#	פער	ההשלכה	מאמץ
15	שתי מערכות סצנות	experience-engine מול experience-runtime — 33 מול 27 אתרי ייבוא, טיפוסים כפולים.	שבוע
16	שתי מערכות תפקידים	5 מול 8 תפקידים, שני מאגרי הענקות, שני צירי בידוד.	4 ימים
17	Studio כפול	(classic) מול (console), ועוד 17 תת-תיקיות ריקות בגיט.	שבוע
18	עורך דף בית ללא דף בית	features/opening נערך ב-Studio אך אינו מרונדר בשום מסלול ציבורי.	יום
19	שאליות N+1	לולאות פר-שורה ב-5 מקומות מזהים.	3 ימים
20	תקרות שקטות	slice(0, 5). על כנסים בהודעות; limit: 500/1000 ללא עימוד.	יומיים
21	סוד TOTP גלוי	נשמר כטקסט במסד.	יום
22	Monday חד-כיווני	רק תוצאה ראשונית; מעברי סטטוס לא מסונכרנים; אין webhooks.	3 ימים

11 הצעות מוצר ופיצ'רים

ההצעות מסודרות לפי יחס ערך/מאמץ. כולן נשענות על מנועים קיימים ואינן דורשות ארכיטקטורה חדשה — למעט המסומנות.

ערך גבוה · מאמץ נמוך

משתתף QR Wallet Pass במקום Apple Wallet ו-Google Wallet לכרטיס הכניסה. מבטל את בעיית הטוקן המודפס, מוסיף עדכוני push על שינויי לויז', ונתפס כמקצועי בהרבה.	Composer שמירת מבנה מלאה הרחבת <code>composer-save-service</code> לשמור סדר, <code>enabled</code>, כותרת ושכפול. הקולקציה כבר תומכת. זה הופך את ה-Studio לעורך אמיתי — הפער היחיד שמפריד בין "נראה גמור" ל"גמור".
משתתף ייצוא ליומן ICS פר-מושב ופר-סדר-יום אישי + מנוי מתמשך. עבודה קיימת חלקית (ראה קומיט "ייצוא ליומן") — כדאי להשלים ל-ICS תקני.	מפיק לוח בקרה ליום האירוע מסך אחד: כמה נכנסו, מי בכל אולם מול קיבולת, איחורים, התראות. הנתונים כבר קיימים — חסר רק המשטח.
תפעול endpoint בריאות + Sentry ה-transport של הלוגר כבר מופשט. חיבור Sentry ו-<code>/api/health</code> = חצי יום, ומחזיר נראות מלאה.	Studio Command Palette רגיסטרי הפעולות ושירות החיפוש כבר בנויים כ-<code>foundation</code>. חסר רק ה-UI. React Aria כבר אושר כספרייה.

ערך גבוה · מאמץ בינוני

משתתף מצב אופליין לכניסה Service worker + snapshot של הכרטיס. הבטחה שכבר קיימת בתיעוד ולא מומשה. קריטי בכנס עם קליטה גרועה.	אמון Audit Trail גלוי קולקציית <code>audit-log</code> + מנוי ל-event bus הקיים + טאב "היסטוריה" בכל אירוע. דרישת סף לרוכש ממשלתי, וממודל כבר בבלופרינטיים.
נטוורקינג המלצות היכרות התאמה לפי תחומי עניין וארגון על בסיס <code>networking-profiles</code> הקיים. "3 אנשים שכדאי לך לפגוש" — הפיצ'ר שהכי מוזכר בסקרי כנסים.	תוכן העברת כל הטקסט ל-CMS הוצאת אובייקטי <code>COPY / TEXT</code> ל-<code>next-intl</code> או לגלובל CMS. מיישר את המערכת עם עיקרון הליבה שלה ומאפשר עריכת טקסט בלי דיפלוי.
Studio ספריית מדיה ארגונית היום מדיה היא פר-אירוע וה-Composer מקבל URL. ספרייה ברמת הארגון + בורר בתוך ה-Composer.	משוב סקרים ומשוב פר-מושב הרחבה טבעית של <code>sessions</code>. מזין את Insights ומספק למפיק את מה שהוא באמת צריך אחרי האירוע.

אסטרטגי · דורש החלטה

ארכיטקטורה

זמן אמת אמיתי

החלפת פולינג ה-12 שניות ב-SSE או WebSocket לצ'אט ולהתראות. משפיע ישירות על יעד 600 המשתמשים. דורש החלטה על תשתית (Redis pub/sub? Pusher).

עסקי

תשלומים

הוצא מתחולת v1 במפורש; חוזה `PaymentProvider` וסטטוס `paymentPending` שמורים. שווה להחליט אם v2 כולל כנסים בתשלום.

מוצר

אתר שיווקי

היום דף הבית הוא הכנס הפעיל. אין דלת כניסה למוצר עצמו — אין דף פתרונות, תמחור או התחברות. החלטה: אתר אמיתי או הפניה?

דומיין

מתנדבים כתת-סוג משתתף

תפקיד `volunteerManager` קיים במודל ההרשאות אך אין דומיין מתנדבים עם שיבוצים. שאלה פתוחה מס' 4.

12 תוכנית עבודה מוצעת

ארבעה ספרינטים. הראשון אינו נראה למשתמש כלל — והוא החשוב ביותר. אין טעם להוסיף פיצ'רים על בסיס שלא ניתן לפרוס בבטחה.

שבוע-שבוע וחצי · P0

ספרינט 1 · חוסמי אוויר

- תיקון בלבול טוקן הכניסה (`entrance` prefix) + בדיקת יחידה שאוכפת קידומות ייחודיות לכל סוגי הטוקנים.
- חיווט `getServerEnv()` להפעלה — `fail-fast` על תצורה חסרה או סוד קצר מ-32 תווים.
- מימוש `ChannelAdapter` אמיתי מאחורי החוזה הקיים (`Resend / SES / SMTP` — ראה פרק 14) + `dispatcher` שמרוקן את ה-`outbox`.
- הקמת מיגרציות Payload ו-**כיבוי** `PAYLOAD_DB_PUSH` **בפרודקשן**.
- הגבלת קצב על קישור-קסם, הרשמה ו-`check-in`. העברת חסימת ההתחברות ל-`Postgres` במקום `Map` בזיכרון.
- כותרות אבטחה ב- `next.config.ts` — `CSP, HSTS, X-Frame-Options, Referrer-Policy`.
- הפעלת `isolation.int.test.ts` ב-CI עם מסד בדיקה + הרחבת `include` של `vitest` ל-`src/**`.

שבוע-שבוע וחצי · P0/P1

ספרינט 2 · ביצועים ותפעול

- אסטרטגיית קאשינג: תגי `revalidateTag` לתוכן ציבורי, `cache()` של `React` לשאילתות חוזרות בבקשה, ו-`revalidate` נקודתי במקום `force-dynamic` גורף.
- החלפת `revalidatePath('/', 'layout')` באינבליציה ממוקדת לפי תג.
- תיקון חמשת מוקדי ה-N+1 המזוהים; החלפת `limit: 500/1000` בעימוד.
- `transport` + `Sentry` ללוגר + `/api/health` + `correlation ids`.
- בדיקת עומס ראשונה מול יעד 600 משתמשים — עם מספרים, לא הערכות.
- הסרת `i.pravatar.cc` ו-`picsum.photos` מ-`remotePatterns` ומהקוד.

שבועיים · P1

ספרינט 3 · ה-Studio כעורך אמיתי

- מימוש `ComposerPersistence` במלואו: `launch`, `restore`, `history`, `saveDraft` — מעל `versions: { drafts: true }` שכבר קיים ב-Payload.
- שמירת סדר, `enabled`, כותרת ושכפול; שמירת טיוטת ה-`identity`.
- `launch-diff` — "מה ישתנה כשתשיק".
- קולקציית `audit-log` + מנוי ל-`event bus` + טאב היסטוריה בכל אירוע.
- ספריית מדיה ארגונית + בורר מדיה בתוך ה-`Composer` (במקום שדה URL).
- בדיקות e2e ראשונות (Playwright): הרשמה מלאה, קישור-קסם, `check-in`.

ספרינט 4 · איחוד וניקוי חוב

שבועיים · P2

- **החלטה ומיזוג:** `experience-engine` מול `experience-runtime` — בחירת דור אחד והגירת השני.
- **איחוד מערכות התפקידים** — אוצר מילים אחד, מאגר הענקות אחד, ציר בידוד אחד.
- סיום ההגירה מ- `(classic)` ל- `(console)`; העברת `actions.ts` החוצה; מחיקת 17 התיקיות הריקות.
- מחיקת `features/opening` או חיווטו למסלול אמיתי.
- העברת כל טקסט המשתתף ל- `next-intl` / `CMS`.
- הצפנת `totpSecret` במנוחה.

מעבר לכך — הפיצ'רים מפרק 11 לפי סדר העדיפות שתקבע: Wallet Pass, לוח יום-האירוע, המלצות היכרות, סקרים, זמן אמת.

13 מוכנות לפרודקשן — רשימת תיוג

פריט	מצב	מה חסר
1	כן	אפליקציה נבנית ועוברת שערים
2	כן	בידוד רב-ארגוני ברמת שורה
3	כן	דו-לשוניות ו-RTL
4	כן	נגישות — מקלדת, ARIA, ניגודיות, reduced-motion
5	כן	רספונסיביות
6	לא	שליחת מיילים
7	לא	מיון מסד DB_PUSH ידני
8	חלקי	גיבוי ושחזור מתורגלים pg_dump קיים; שחזור לא תורגל
9	חלקי	אחסון מדיה מתמיד S3 מותנה בהגדרה
10	לא	הגבלת קצב אין כלל
11	לא	כותרות אבטחה אין headers()
12	לא	אימות משתני סביבה הסכמה קיימת, לא נקראת
13	לא	ניטור והתראות אין Sentry, transport
14	לא	endpoint בריאות אין
15	לא	קאשינג הכול force-dynamic
16	לא	בדיקת עומס ל-600 משתמשים לא בוצעה מעולם
17	לא	CI אוטומטי שערים ידניים
18	לא	בדיקות e2e אין מסגרת
19	לא	audit trail ממודל בלבד
20	לא	סקירת אבטחה שני ממצאים חמורים פתוחים

ציון מוכנות: 5 מתוך 20 מלאים. אך רוב הפריטים החסרים הם ימים, לא שבועות — הבסיס הארכיטקטוני שנבנה נכון הוא מה שהופך את זה לאפשרי.

14 החלטות שנדרשות ממך

הבאות חוסמות עבודה. אין להן ברירת מחדל סבירה שאפשר לנחש.

#	החלטה	האפשרויות	מה זה חוסם
1	ספק מייל	Resend (הכי פשוט) · AWS SES (הכי זול בקנה מידה) · SMTP ארגוני/ממשלתי · SendGrid	ספרינט 1 כולו. בלי זה אין לולאת משתתף.
2	יעד פריסה סופי	שרת Hetzner יחיד (כפי שמתועד) · ענן מנוהל · on-prem ממשלתי	אחסון מדיה, סקילינג, מודל הגיבוי, אסטרטגיית זמן-אמת
3	דור מנוע החוויה	מיזוג ל- experience-runtime · מיזוג ל- experience-engine · השארה מכוונת	ספרינט 4 וכל פיתוח סצנות עתידי
4	מודל תפקידים	5 של permission-engine · 8 של src/auth · מודל שלישי מאוחד	איחוד ההרשאות, מודול Settings, ניהול צוות
5	אתר שיווקי	אתר אמיתי (פתרונות, תמחור, התחברות) · הפניה פשוטה ל-Studio · השארת המצב הנוכחי	הדלת הראשית של המוצר
6	זמן אמת	השארת פולינג 12 ש' · WebSocket · SSE + Redis	יעד 600 המשתמשים, עלות התשתית
7	מתנדבים	תת-סוג משתתף עם שיבוצים · דחייה ל-v2	תפקיד volunteerManager קיים ואין לו דומיין
8	תשלומים	נשאר מחוץ לתחולה · נכנס ל-v2	חזרה PaymentProvider וסטטוס paymentPending שמורים

ההמלצה שלי — אם רוצים דבר אחד להתחיל ממנו

תיקון טוקן הכניסה (שעה) ואימות משתני הסביבה (שעתיים). שניהם קטנים, שניהם חמורים, ושניהם חוסמים כל שיחה על הדפסת תגים או פריסה. אחריהם — ספק המייל, כי הוא ההחלטה היחידה שחוסמת את הספרינט השלם הראשון.

כל הממצאים בדוח זה מבוססים על קריאת קוד המקור בפועל בענף הנוכחי (קומיט 7bf6f57), ולא על התייעוד ב- docs/. במקומות שבהם התייעוד והקוד נחלקים — הקוד גובר. מסמכי System-State-and-Gaps.md ו-Development-Report-14.md מתוארכים ל-16-17 ביולי; פיתוח משמעותי התבצע אחריהם (Program, Networking, קונסולת Studio), ולכן חלק מהפערים שנרשמו שם כבר נסגרו.